



PS-NC-005

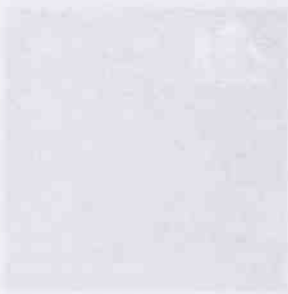
**POLITICA GENERAL DE SEGURIDAD DE LA
INFORMACIÓN Y CIBERSEGURIDAD DEL MINISTERIO
DE SALUD**

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v05 – mayo 2025

	Responsable	Fecha	Firma
Elaborado	Pablo Fabres F. – Jose Villa C.	23.05.25.	
Revisado	Jose Villa C.	25.05.25.	
Aprobado	Jorge Herrera R.	23/05/25	





PS-NC-005

POLITICA GENERAL DE SEGURIDAD DE LA
INFORMACION Y CIBERSEGURIDAD DEL MINISTERIO
DE SALUD
Sistema de Gestión de Seguridad de la Información – Nivel Central



CONTENIDO

1 PROPÓSITO4

2 ALCANCE O ÁMBITO DE APLICACIÓN.....4

3 ROLES Y RESPONSABILIDADES.....4

4 MATERIAS QUE ABORDA.....6

5 PRINCIPIOS BÁSICOS6

6 OBJETIVOS DE LA GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD EN EL MINISTERIO DE SALUD7

7 LINEAMIENTOS ESPECIFICOS8

8 GESTIÓN DE LA POLITICA Y OTROS DOCUMENTOS DEL SISTEMA DE GESTION DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD.....14

9 IDENTIFICACIÓN DE RIESGOS15

10 TERMINOLOGÍA15

11 REVISIÓN Y MEDICIÓN16

12 CUMPLIMIENTO DE LA PRESENTE POLITICA.....16

13 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS.....17

14 INDICADORES18

15 MECANISMO DE DIFUSIÓN.....19

16 PERÍODO DE REVISIÓN.....19

17 CONTROL DE VERSIONES.....20

18 REFERENCIAS.....20



1 PROPÓSITO

El propósito de esta Política General de Seguridad de la Información y Ciberseguridad es establecer un marco de referencia y directrices que ayuden a proteger la información y los sistemas del Ministerio de Salud (MINSAL) de manera integral y efectiva, que permita salvaguardar la confidencialidad, integridad y disponibilidad de los activos de información, así como mitigar los riesgos relacionados con la ciberseguridad.

2 ALCANCE O ÁMBITO DE APLICACIÓN

El alcance de la Política General de Seguridad de la Información y Ciberseguridad abarca de manera integral y transversal todas las operaciones, sistemas, recursos y procesos relacionados con la gestión de la información y la ciberseguridad en el MINSAL.

Aplicable a todos los funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y Redes Asistenciales, en el Nivel Central.

Esta política abarca los siguientes controles definidos en la norma NCh-ISO 27001 del año 2022:

Controles

- A1.05-5.1 Políticas para la seguridad de la información.
- A1.05-5.2 Roles y responsabilidades en seguridad de la información
- A1.05-5.36 Cumplimiento de Políticas, reglas y normas de seguridad de la información.

3 ROLES Y RESPONSABILIDADES

3.1 Comité de Seguridad de la Información

- Desarrollar y revisar políticas, directrices y procedimientos relacionados con la seguridad de la información y ciberseguridad de la organización. Esto incluye definir estándares de seguridad y mejores prácticas.
- Supervisar la implementación de la estructura documental del Sistema de Seguridad de la Información aplicable al Ministerio.
- Proponer estrategias o soluciones específicas para implementar o controlar los componentes de la estructura documental del Sistema de Seguridad de la Información.
- Arbitrar conflictos en materia de seguridad de la información y los riesgos asociados, y proponer soluciones sobre ello.
- Revisar y monitorear los incidentes de seguridad de la información a fin de establecer acciones preventivas y correctivas.
- Coordinarse con el Comité de Riesgos de la Institución, para mantener estrategias comunes de gestión.
- Revisar los elementos del Sistema de Seguridad de la Información y proponer mejoras a través del Encargado de Seguridad y Ciberseguridad de la institución.
- Difundir los componentes de la estructura documental del Sistema de Seguridad de la Información a través de la Intranet y los medios de comunicación establecidos dentro del Ministerio de Salud.
- Monitorear cambios significativos que pudieran variar los riesgos presentes en la Institución.
- Establecer acciones y proponer iniciativas para mejorar la seguridad de la información y Ciberseguridad en el Ministerio.
- Supervisar la realización de auditorías de Seguridad de la Información y Ciberseguridad internas o externas.



3.2 Encargado de Seguridad de la Información y Ciberseguridad

- Responsable institucional de seguridad de la información y ciberseguridad, será encargado de velar por la seguridad de la información y ciberseguridad dentro del Ministerio, asegurar el desarrollo, cumplimiento y actualización de la Política y de gestionar la administración de la seguridad de la información y ciberseguridad.
- Actuar como contraparte frente al Ministerio del Interior en materias relativas a Ciberseguridad de la información para el nivel central del Ministerio de Salud.
- Alinear los esfuerzos de las distintas áreas de la institución, respecto a la protección de los sistemas tecnológicos y a la información contenida en ellos, según los criterios de Ciberseguridad.
- Gestionar internamente el tratamiento de incidentes que estén vinculados a los activos de información en la Institución, identificados y/o reportados tanto por el Ministerio del Interior como por instancias internas, efectuando la reportabilidad y el seguimiento adecuado a dichos eventos.
- Apoyar el proceso de Sensibilización en Materias de Ciberseguridad al Interior de la Institución.
- Presidir el comité que tendrá a su cargo la actualización de políticas de Ciberseguridad y Seguridad de la Información al interior de la organización.
- Coordinar las acciones necesarias para resguardar y asegurar la continuidad del negocio frente a incidentes de Ciberseguridad.
- Resguardar que se informe adecuadamente a todas las personas naturales y jurídicas que puedan tener acceso a los activos de información del Ministerio de Salud, acerca de las Políticas de Ciberseguridad y Seguridad de la Información vigentes en el Ministerio, y en particular sobre las obligaciones que les correspondan en relación con la gestión de incidentes.
- Comunicar al CSIRT Nacional los incidentes de ciberseguridad de los que tenga conocimiento en ejercicio de sus funciones, a través de la plataforma oficial <https://portal.anci.gob.cl>, en representación del Subsecretario de Salud Pública o del Subsecretario de Redes Asistenciales, en sus calidades de jefes de servicio, según sea el caso.

3.3 Encargado de los Activos de Información

- Responsable de su identificación y clasificación, así como gestionar el riesgo y niveles de seguridad asociados.
- El desempeño de estas funciones no podrá ser externalizado bajo ninguna forma.

3.4 Usuarios finales.

- Se debe entender como usuarios finales a todos quienes tienen la responsabilidad de acatar las políticas y normativas definidas, independiente que además tengan otros roles nominados en este ámbito. Debe considerar:
 - A todos los funcionarios (planta, contrata, reemplazos y suplencia),
 - Personal a honorarios,
 - Terceros (proveedores, compra de servicios, tratamiento por encargo, servicios externalizados, etc.).
- Los requerimientos de seguridad hacia terceros y personal a honorarios o subcontratados, si procede, deben estar considerados en los TDR: Términos de



referencia del acuerdo base del servicio contratado, bases de licitación, y contratos respectivos.

- Las principales responsabilidades de los usuarios sobre el uso de la información institucional son:
 - Utilizar la información sólo para el propósito para el que recibió autorización de uso.
 - Conocer las políticas y procedimientos de seguridad de la información que se han institucionalizado.
 - Cumplir con los controles establecidos en las políticas y procedimientos definidos en el sistema de seguridad de la información, de las Subsecretarías de Salud Pública y de Redes Asistenciales, o el texto que lo reemplace.
 - Tomar las medidas adecuadas para evitar que la información se divulgue o use sin autorización.
 - Comunicar los incidentes relativos a la seguridad de la información.
 - Responder por el uso de cualquier recurso de procesamiento de la información y cualquier uso desarrollado bajo su responsabilidad.

4 MATERIAS QUE ABORDA

- Políticas para la seguridad de la información.
- Revisión de las políticas de seguridad de la información.
- Roles y responsabilidades de la seguridad de la información y Ciberseguridad.
- Revisión independiente de la seguridad de la información.

5 PRINCIPIOS BÁSICOS

5.1 Declaración Institucional

El Ministerio de Salud se compromete a gestionar de manera continua la seguridad de la información y ciberseguridad, en conformidad con la normativa gubernamental vigente. Para lograr este propósito, llevará a cabo las acciones necesarias para establecer niveles aceptables de seguridad determinados internamente, basándose en metodologías y técnicas estándares. El objetivo es instaurar un ciclo de mejora constante y sostenible que asegure la integridad, confidencialidad y disponibilidad de los activos de información esenciales para la institución, como un pilar fundamental en la gestión de sus procesos.

En este contexto, el MINSAL implementará un plan de mejora continua fundamentado en la normativa NCh-ISO 27001:2022, que establece los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI). Este enfoque busca optimizar y reforzar la protección de los activos de información pertenecientes a la institución. Asimismo, considerará la adopción de estándares reconocidos a nivel nacional e internacional, para complementar y fortalecer las prácticas existentes, adaptándolas a las necesidades específicas del sector salud. Este compromiso se alinea con lo que establece la Ley N° 21.663 sobre el Marco de Ciberseguridad, que obliga a las instituciones públicas a crear estructuras de gobernanza y a implementar medidas efectivas para proteger sus sistemas críticos de información.

Dicho sistema se cimentará en directrices claras que se ajusten a las demandas institucionales y a los requisitos regulatorios pertinentes. La implementación exitosa de estas



medidas permitirá asegurar la confiabilidad y robustez de las prácticas relacionadas con la seguridad de la información y la ciberseguridad en MINSAL.

A raíz de lo expuesto previamente, la dirección del MINSAL establece los siguientes principios que sustentarán la seguridad institucional:

- i. Incentivar la percepción de la Información como un recurso esencial en el ámbito de la salud, reconociendo su valor estratégico y su papel fundamental en la toma de decisiones.
- ii. Proteger la privacidad y confidencialidad de toda información sensible o personal, independientemente de su formato o medio de almacenamiento, a fin de respetar los derechos individuales y la integridad de los datos.
- iii. Preservar la integridad de los datos, reconociendo que su exactitud y actualización pueden ser vitales.
- iv. Garantizar el acceso a la información crítica únicamente para usuarios autorizados y en momentos pertinentes, asegurando así la disponibilidad y el uso adecuado de los recursos.
- v. Implementar un modelo de gestión de riesgos para la seguridad de la información, con el fin de identificar y mitigar riesgos relevantes mediante controles apropiados.
- vi. Cumplir con el marco normativo establecido para la seguridad de la información en el sector salud e institucional, a través de la gestión de controles definidos.
- vii. Realizar respaldos seguros que permitan la protección de la información gestionada por el sector salud y definir responsabilidades y frecuencia de pruebas de restauración para sistemas críticos.
- viii. Establecer mecanismos para identificar, analizar, notificar, responder y aprender de debilidades e incidentes de seguridad de la información, para su mitigación y prevención.
- ix. Desarrollar programas educativos para el personal del sector salud, con el propósito de mejorar su comprensión y competencias en el ámbito de seguridad de la información y ciberseguridad
- x. Apoyar la construcción de una plataforma de intercambio recíproco de experiencias y aprendizaje en todos los aspectos de la seguridad de la información del sector Salud.
- xi. Las responsabilidades frente a la seguridad de la información serán definidas, compartidas, publicadas y aceptadas por cada uno de los funcionarios, proveedores o terceros.
- xii. Establecer lineamientos de interoperabilidad para asegurar una protección cohesiva y robusta de los sistemas y datos, permitiendo una colaboración segura y eficiente entre diferentes sistemas y plataformas Ministeriales.
- xiii. Promover el desarrollo y la implementación de sistemas de Inteligencia Artificial de forma ética, segura y centrada en las personas, garantizando que la implementación de la IA en el sector salud se realice de manera responsable y en beneficio de la sociedad.

6 OBJETIVOS DE LA GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD EN EL MINISTERIO DE SALUD

6.1 Objetivo General

Establecer una visión estratégica en lo que respecta a la seguridad de la información y la ciberseguridad que dote a la institución de un marco integral de seguridad de la información y ciberseguridad que promueva un entorno seguro y consciente, acorde con los desafíos actuales en materia de seguridad de la información, que permita garantizar la protección, confidencialidad, integridad y disponibilidad de los activos de información de del Ministerio



de Salud, así como la mitigación de riesgos cibernéticos, con el propósito de salvaguardar los intereses públicos, asegurar el cumplimiento de las obligaciones legales y normativas, y fortalecer la confianza de los ciudadanos y partes interesadas en la gestión de datos y servicios electrónicos ofrecidos por la institución.

Para ello, la Política establece directrices generales en el ámbito de la seguridad de la información y la ciberseguridad para el Ministerio que permitan mantener niveles aceptables de seguridad de los componentes de software y hardware, así como de los sistemas informáticos y los datos que gestionan, almacenan, procesan e interoperan.

6.2 Objetivos Específicos

- Disponer la obligación de Identificar y registrar los activos de información relevantes, tanto directos como indirectos, presentes en los procesos institucionales. Esto abarca tanto los procesos críticos institucionales como los de soporte.
- Establecer los roles y responsabilidades que doten a MINSAL de un esquema de gobernanza de la seguridad de la información que sea consistente con las necesidades institucionales y se haga cargo los desafíos de los riesgos que emanan de los avances tecnológicos.
- Implementar un modelo de gestión de riesgos para la seguridad de la información y ciberseguridad, que permitan una comprensión precisa de las amenazas potenciales, con el fin de identificar y mitigar riesgos relevantes mediante controles apropiados.
- Garantizar la protección integral de la información en términos de su procesamiento, conservación y transmisión. Esto implica prevenir cualquier acceso no autorizado, revelaciones accidentales, errores, fraudes, sabotajes, violaciones de privacidad y otras acciones que puedan ponerla en peligro.
- Establecer protocolos claros para la gestión de incidentes de seguridad de la información y ciberseguridad, con el fin de detectar, notificar, responder y recuperarse de manera eficiente ante cualquier evento no deseado
- Utilizar y mantener de manera efectiva la estructura y el conjunto de estándares, políticas y procedimientos en materia de seguridad de la información y ciberseguridad.
- Minimizar la probabilidad de eventos contingentes que puedan interrumpir la operación normal del negocio y reducir el impacto de posibles daños a las instalaciones, medios de almacenamiento, equipos de procesamiento y comunicación.
- Aplicar planes de continuidad operacional para abordar situaciones contingentes que puedan ocasionar interrupciones en la operación del negocio.
- Sensibilizar y capacitar a los funcionarios del MINSAL acerca de su responsabilidad en el mantenimiento de la seguridad de la información y su uso adecuado. Esto incluye la creación de una cultura organizacional que integre la seguridad de la información y ciberseguridad como un aspecto fundamental en los procesos y servicios del Ministerio.

7 LINEAMIENTOS ESPECIFICOS

7.1 Gobernanza y Responsabilidades

La Ley N° 21.663 Ley Marco sobre Ciberseguridad, establece una estructura de gobernanza para la ciberseguridad en Chile. Por otro lado, el Decreto Supremo N° 7/2023 establece la



Norma Técnica de Seguridad de la Información y Ciberseguridad, en línea con la Ley N° 21.180 sobre Transformación Digital del Estado, que exige que los organismos de la Administración del Estado definan roles específicos, incluyendo un responsable institucional de seguridad de la información y ciberseguridad, así como un encargado de los activos de información.

Complementando estos marcos, el NIST Cybersecurity Framework 2.0 resalta la importancia de la gobernanza en ciberseguridad. Este marco internacional enfatiza que una gobernanza efectiva que permite a la alta dirección entender y gestionar los riesgos de ciberseguridad, alineándolos con la estrategia organizacional y enfocándose en cómo estas amenazas pueden afectar los objetivos institucionales.

En conjunto, estos instrumentos normativos y técnicos crean una estructura de gobernanza integral que fortalece la capacidad del Estado para proteger sus sistemas críticos de información y responder de manera efectiva a las amenazas cibernéticas.

Siguiendo estas pautas, el MINSAL cuenta con una estructura de gobernanza de la ciberseguridad que incluye:

- **Unidad de Seguridad de la Información y Ciberseguridad:** Esta unidad tiene la responsabilidad de definir, impulsar y controlar las políticas y estrategias en esta área, participando activamente en la toma de decisiones institucionales. Cuenta con los recursos humanos y materiales necesarios para llevar a cabo sus funciones y dependerá funcionalmente del Departamento de Tecnologías de la Información y Comunicación, manteniendo su independencia respecto a los responsables operativos de los sistemas de información.
- **Encargado de Seguridad de la Información y Ciberseguridad (CISO):** Un profesional con las competencias adecuadas para liderar la unidad mencionada, que con capacidad de decisión e influencia en la organización, y que reportadirectamente al más alto nivel institucional.
- **Comité de Seguridad de la Información y Ciberseguridad:** Que incluye a representantes de las áreas ministeriales relevantes, encargado de supervisar la ejecución de estrategias de seguridad y la respuesta ante incidentes.

7.2 Estrategia de Seguridad y Plan Director de Seguridad

El MINSAL establece su estrategia de seguridad de la información y ciberseguridad mediante un Plan Director. Este plan detalla iniciativas específicas para salvaguardar los activos digitales y los procesos tecnológicos esenciales en el sector salud. Se fundamenta en un enfoque de gestión de riesgos y se ajusta a estándares tanto nacionales como internacionales.

Este instrumento permite planificar, ejecutar y supervisar medidas de protección, asegurando la continuidad operativa, la respuesta ante incidentes y la resiliencia digital.

Para una implementación efectiva se requiere:

- **Sponsor directivo:** Un representante de la alta dirección de la institución, el cuál desempeñará un papel fundamental para asegurar que los objetivos de la política de seguridad de la información de la institución sean compatibles y vinculantes con el cumplimiento de objetivos estratégicos de la institución, garantizando además, que las responsabilidades y autoridades pertinentes para los roles relacionados con la seguridad de la información sean claramente asignados y comunicados.



- **Recursos adecuados:** La alta dirección de la institución debe asegurar que se asignen los recursos necesarios para respaldar la seguridad de la información y ciberseguridad, considerando recursos financieros, tecnológicos y humanos.
- **Compromiso sectorial:** Es esencial obtener la participación y el compromiso activo de las instituciones del sector, su colaboración no solo contribuirá a la eficacia del sistema de gestión de la seguridad de la información y ciberseguridad a nivel sectorial y nacional, sino que también se espera que respalden con otros roles de gestión relevantes, según corresponda a sus áreas de responsabilidad.

7.3 Gestión de Seguridad de la Información y Ciberseguridad de forma transversal en la Institución

La Gestión de Seguridad de la Información y Ciberseguridad se deberá implementar de manera transversal en toda la Institución, y no limitarse exclusivamente a la responsabilidad del departamento de Tecnologías de Información y Comunicación. Esta gestión debe abordar procesos interdepartamentales y contar con la participación de los responsables de dichos procesos.

7.4 Seguridad Informática de los Recursos Humanos

Se debe establecer la necesidad de informar y educar a todos los empleados y terceros relacionados con el ministerio, sobre lo que se espera de ellos en materia de seguridad de la información tanto en sus actividades en la red local como en sus conexiones externas a la organización.

7.5 Gestión de Activos

Realizar gestión y protección efectiva de los activos, considerando su clasificación según su nivel de importancia, representa una prioridad primordial para el MINSAL. Estos activos abarcan no solo el hardware y el software, sino también los dispositivos de comunicación, elementos de apoyo, información y datos en todas sus formas y formatos.

La clasificación de los activos se realiza considerando aspectos clave como la confidencialidad, integridad y disponibilidad de los datos, así como las funciones que dichos activos respaldan y la normativa vigente aplicable.

7.6 Autenticación, autorización y control de Acceso

Es esencial garantizar que el acceso de los usuarios esté debidamente autorizado y prevenir el acceso no autorizado a los sistemas de información. Para lograr esto, se deben de establecer procedimientos formales de control en la asignación de derechos de acceso a los sistemas de información, abarcando todas las etapas del ciclo de vida del usuario, desde su registro inicial hasta su desvinculación.

La asignación de derechos de acceso debe ser abordada con especial atención para evitar la asignación de privilegios que permitan a los usuarios eludir los controles del sistema. Para reforzar estas medidas, se implementará una política de escritorio y pantalla limpios, procedimiento de habilitación y deshabilitación de perfiles y derechos de acceso de acuerdo con las necesidades institucionales, de forma tal que se reduzca el riesgo de acceso no autorizado como el peligro de robo o daño a documentos y otros medios de almacenamiento de información.



El enfoque integral de autenticación, autorización y control de acceso es crucial para asegurar la confidencialidad, integridad y disponibilidad de los activos de información, así como para prevenir posibles vulnerabilidades y salvaguardar la seguridad de los sistemas de información en su totalidad.

7.7 Seguridad física y ambiental

Se deben identificar los riesgos vinculados al acceso físico a las instalaciones y a la infraestructura tecnológica de la institución, tanto por parte de los funcionarios como de terceros. El objetivo primordial es prevenir cualquier tipo de acceso no autorizado, así como evitar daños e interferencias en las instalaciones y en la información resguardada en ellas.

7.8 Seguridad operativa

Se debe implementar mecanismos de gestión y monitoreo destinados a salvaguardar la infraestructura de tecnologías de información ante posibles amenazas, tanto físicas como tecnológicas. El propósito principal es optimizar la operación de las plataformas tecnológicas, garantizando un procesamiento preciso y seguro de la información en el ámbito ministerial.

7.9 Adquisición, desarrollo y mantenimiento de los sistemas

La adquisición, desarrollo y mantenimiento de sistemas de información abarca sistemas operativos, infraestructura, aplicaciones empresariales, servicios y aplicaciones desarrolladas internamente por la institución. Por lo que será esencial la identificación y el acuerdo de todos los requisitos de seguridad antes de la fase de desarrollo y/o implementación de los sistemas. Estos requisitos deben ser debidamente justificados, acordados y documentados como parte integral de los procedimientos para sistemas de información.

En el caso de desarrollos de software internos o aquellos contratados a terceros, es crucial asegurar que la seguridad sea un componente integral de los sistemas de información desarrollados. Esto implica la inclusión de los requisitos de seguridad desde la etapa de especificación del software y a lo largo de todo el ciclo de vida del programa computacional de que se trate.

La ciberseguridad se integra en cada etapa para garantizar la protección adecuada de la información y la continuidad operativa, respaldando así la confidencialidad, integridad y disponibilidad de los activos de información y los sistemas involucrados.

7.10 Interoperabilidad

Se deberán definir estándares y protocolos de comunicación compartidos para asegurar que diferentes sistemas y tecnologías puedan interactuar de manera segura y eficiente. Establecer el cifrado y autenticación en las comunicaciones entre sistemas y dispositivos para prevenir accesos no autorizados y asegurar la confidencialidad de los datos transmitidos.



Definir procedimientos seguros para el intercambio de datos, con mecanismos de validación de integridad para prevenir alteraciones no autorizadas. Así como la definición de planes de contingencia y procedimientos de recuperación ante fallos que consideren la interoperabilidad, de modo que cualquier interrupción no comprometa la seguridad global. La incorporación de estos elementos asegurará una protección cohesiva y robusta de los sistemas y datos, permitiendo una colaboración segura y eficiente entre diferentes sistemas y plataformas Ministeriales.

7.11 Ciberseguridad

Se debe establecer un conjunto integral de prácticas y políticas destinadas a proteger los sistemas, redes y datos contra amenazas cibernéticas. Esto debe incluir la implementación de medidas de autenticación sólidas, el uso de encriptación para proteger la confidencialidad de la información, la actualización constante de software y sistemas para mitigar vulnerabilidades, la capacitación periódica del personal en concienciación sobre seguridad, la monitorización constante de actividad sospechosa y la elaboración de planes de respuesta ante posibles incidentes, todo ello con el objetivo de mantener la integridad, disponibilidad y privacidad de los activos digitales de manera efectiva y continua.

7.12 Gestión de Incidentes de Seguridad de la Información y Ciberseguridad

Es esencial garantizar la comunicación oportuna de debilidades, problemas y eventos de seguridad relacionados con los sistemas de información, permitiendo la adopción inmediata de medidas correctivas. Para lograrlo, se debe establecer un procedimiento formal para informar sobre cualquier evento de seguridad de la información, así como para gestionar la respuesta ante incidentes.

Además, se debe implementar un proceso de escalado que indique las acciones a tomar al recibir un informe de evento de seguridad de la información. Estos procedimientos serán ampliamente difundidos para que todos los miembros del equipo estén al tanto.

- Todo incidente de ciberseguridad debe ser reportado siguiendo el procedimiento establecido por el Decreto N° 295/2025 del Ministerio del Interior y Seguridad Pública. Esto implica que los reportes deben enviarse al CSIRT Nacional a través de la plataforma oficial (<https://portal.anci.gob.cl>) dentro de los plazos establecidos: se debe emitir una alerta temprana en un máximo de 3 horas desde la detección, un informe de actualización dentro de las 72 horas siguientes, y un informe final en un plazo de 15 días corridos. Además, los operadores de importancia vital deben presentar un plan de acción en un plazo no mayor a 7 días corridos desde que se detecta el incidente.
- Es fundamental mantener un registro actualizado de todos los incidentes, donde se detalle su detección, análisis, respuesta y resolución. Este registro ayudará a identificar tendencias, evaluar la efectividad de las medidas de seguridad implementadas y a mejorar continuamente los procesos de gestión de incidentes.
- También es importante promover programas de capacitación y/o concienciación para todos los funcionarios de la Institución, con el fin de fomentar una cultura de seguridad de la información y ciberseguridad. Esto asegurará que estén preparados para identificar y reportar incidentes de manera oportuna, mejorando así la capacidad de respuesta ante cualquier eventualidad.



7.13 Aspectos de la continuidad del negocio

La planificación de la continuidad del negocio en el ámbito de la seguridad de la información se erige como un pilar fundamental para proteger la estabilidad de las operaciones y salvaguardar los activos críticos, brindando así la tranquilidad de una respuesta efectiva ante situaciones adversas.

Al respecto, se requiere adoptar medidas preventivas y de mitigación para evitar y reducir al mínimo los impactos de los incidentes de seguridad de la información que puedan afectar la integridad de las redes, equipos y sistemas esenciales para la prestación de servicios. El objetivo principal es asegurar la continuidad operativa y facilitar la recuperación efectiva de la plataforma tecnológica y sus servicios.

En todos los escenarios, será imprescindible desarrollar, implementar, poner en práctica y evaluar un plan de respuesta integral que brinde una cobertura adecuada a las redes, equipos y sistemas. Este plan se alineará con estándares internacionales o nacionales de amplio reconocimiento y se centrará en garantizar, desde la perspectiva de los clientes, la preservación de la integridad, disponibilidad y confidencialidad de la información.

7.14 Cumplimiento

Anualmente, se llevará a cabo la generación de procedimientos de auditoría con el propósito fundamental de prevenir cualquier tipo de incumplimiento de leyes, estatutos, regulaciones u obligaciones contractuales, así como de los requisitos de seguridad de la información y ciberseguridad que puedan afectar el diseño, operación, uso y gestión de los sistemas de información Ministeriales. Estos procedimientos establecerán plazos periódicos para garantizar la ejecución de un control riguroso sobre la normativa vigente en esta materia. Asimismo, se realizará el seguimiento y se atenderán de manera efectiva las recomendaciones pertinentes para asegurar la conformidad con las regulaciones en constante evolución.

7.15 Arquitectura de Referencia

Se deben desarrollar e implementar sus sistemas tecnológicos de acuerdo con su Arquitectura de Referencia del MINSAL, que ofrece una visión completa y organizada del ecosistema tecnológico institucional.

Los proyectos deben integrar principios arquitectónicos establecidos por el MINSAL, tales como la seguridad y privacidad de la información, la interoperabilidad, la gestión de datos, la infraestructura y los usuarios. Además, es fundamental que se tomen en cuenta patrones de diseño, metodologías de desarrollo y directrices clave en seguridad, cumplimiento normativo y rendimiento.

Estas pautas son aplicables a todas las iniciativas de desarrollo de sistemas en el sector salud, garantizando que cada proyecto tecnológico se diseñe y ejecute de manera coherente, segura y enfocada en la mejora continua de los servicios de salud.



7.16 Uso de IA y Transparencia Algorítmica

Es fundamental asegurar que el uso de sistemas de Inteligencia Artificial (IA) en el ámbito de la salud se lleve a cabo de forma segura, ética y transparente, en el sentido que sus resultados sean auditables, cumpliendo con la legislación vigente.

Con el objetivo de asegurar que las aplicaciones de IA en el sector público se alineen con los valores de protección de derechos, transparencia y seguridad de la información, además de fomentar la eficiencia y mejorar la calidad de los servicios público. Siguiendo los siguientes lineamientos, que buscan promover un entorno de confianza y responsabilidad.

- Los datos que se utilizan para desarrollar y operar sistemas de inteligencia artificial deben ser guardados y procesados en entornos seguros. Es fundamental aplicar medidas de cifrado y controles de acceso rigurosos para evitar accesos no autorizados. Además, es importante implementar técnicas de anonimización o pseudonimización para salvaguardar la privacidad de los pacientes.
- Los sistemas de IA deben permitir la trazabilidad y auditabilidad de sus procesos, lo que facilita que tanto los profesionales de la salud como los pacientes comprendan los resultados. Esto incluye una documentación adecuada de los algoritmos y la capacidad de explicar las decisiones automatizadas cuando sea necesario.
- Antes de usar datos personales de pacientes en sistemas de IA para finalidades distintas de las prestaciones de salud que se le otorguen, es crucial obtener su consentimiento informado, mediante documentos comprensibles, de acuerdo con las necesidades del paciente, que incluyan el tipo de datos que serán objeto de tratamiento, el propósito y alcance del uso de sus datos en estos sistemas, los destinatarios de la información, y si se anonimizarán o seudonimizarán los datos.
- El desarrollo y uso de la IA en el ámbito de la salud deben alinearse con principios éticos que respeten la dignidad y los derechos humanos de los pacientes. Además, deben cumplir con las leyes de protección de datos y privacidad vigentes.
- La implementación de sistemas de IA debe incluir mecanismos de supervisión humana para garantizar la responsabilidad y la rendición de cuentas en las decisiones automatizadas. Esto significa que debe haber posibilidad de intervención humana en situaciones donde los sistemas de IA puedan impactar significativamente la salud o los derechos de los pacientes.

8 GESTIÓN DE LA POLITICA Y OTROS DOCUMENTOS DEL SISTEMA DE GESTION DE SEGURIDAD DE LA INFORMACIÓN Y CIBERSEGURIDAD

La documentación aplicable a las Subsecretarías de Salud Pública y de Redes Asistenciales deben asegurar:

- La integración del modelo de seguridad de la información, con las metodologías y políticas existentes para ambas subsecretarías.
- Que se cumplan las normas legales y reglamentarias referidas a seguridad de la información y ciberseguridad, tanto para la información, como para los medios que la contienen.
- Que la información cumpla con los niveles de autorización y responsabilidad correspondientes para su utilización, divulgación, administración, seguimiento y custodia.
- Que la información, sus medios de procesamiento, conservación y transmisión se encuentren protegidos del uso no autorizado o revelaciones accidentales, errores, fraudes, sabotajes, espionaje, violación de la privacidad y otras acciones que pudieran perjudicarla.



- Que los medios de procesamiento, conservación y comunicación de la información cuenten con medidas de protección física que eviten el acceso y/o utilización indebida por personal no autorizado.
- Que los derechos de propiedad sobre la información y sistemas estén establecidos.
- Que las comunicaciones internas y externas cuenten con mecanismos que protejan la integridad, disponibilidad y confidencialidad en la transmisión de información.
- Que se delimiten los ámbitos físicos de acción de las políticas de seguridad, dependiendo de los distintos niveles de riesgo que presentan los medios de procesamiento, conservación y comunicación.
- Que el acceso a los servicios de ambas subsecretarías ya sea por medios internos o externos, se realice de acuerdo con las atribuciones de las personas o entidades que las utilicen.
- Que las actividades y uso de recursos críticos, relacionados con productos y servicios, sean monitoreados y su información sea conocida en forma oportuna por los niveles correspondientes.

9 IDENTIFICACIÓN DE RIESGOS

A lo menos cada dos años el Comité de Seguridad de la Información Nivel Central, debe gestionar la actualización de los riesgos de seguridad de la información del Nivel Central, que debe ser construido a partir del análisis de las amenazas y vulnerabilidades a los que se encuentran expuestos los activos de la información relevantes. La metodología de análisis y gestión de riesgos debe estar enfocada en los procesos de provisión institucional, sus actividades, actores y activos, siendo referente:

- Norma NCh-ISO 31000:2018 sobre directrices para la gestión de riesgos.
- Norma NCh-ISO/IEC 27005:2020 sobre las tecnologías de información, y la gestión del riesgo de seguridad de la información.
- Política General de Seguridad de la Información del MINSAL [1].
- Procedimiento de Riesgos de Seguridad de la Información del MINSAL [2].

10 TERMINOLOGÍA

En este apartado se introducen los términos utilizados en la gestión de riesgos, su comprensión facilitará el resto de la lectura de la presente política.

- **Activo:** Todo elemento lógico o físico, componente de hardware, equipamiento o sistema relacionado con la información, que permita su generación, almacenamiento, soporte, envío o intercambio, sea a otros órganos de la Administración del Estado o con personas naturales o jurídicas.
- **Activo de Información:** Datos o información cuyo tratamiento es esencial para el funcionamiento y desarrollo del órgano de la Administración del Estado que lo utiliza, genera, almacena, envía o intercambia, y que deben ser protegidos en su confidencialidad, integridad, disponibilidad u otros factores de importancia.
- **Ciberseguridad y Seguridad de la Información:** Conjunto de acciones, políticas, medidas preventivas y reactivas destinadas a la prevención, mitigación, manejo, respuesta y estudio de las amenazas y riesgos de incidentes de seguridad, a la reducción de sus efectos y el daño causado; antes, durante y después de su ocurrencia; respecto de los activos y activos de información y la continuidad de servicios, con el fin de proteger, preservar y restablecer la confidencialidad, integridad y disponibilidad de



aquellos y de las plataformas electrónicas de los órganos de la Administración del Estado, aumentando su resiliencia en el tiempo.

- **Gestión de Riesgo:** Proceso estructurado y proactivo por el cual se identifican, evalúan, controlan y tratan los riesgos derivados de una o más amenazas determinadas.
- **Incidente de Seguridad:** Todo evento de seguridad o una serie de ellos, de carácter indeseado o inesperado, que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los sistemas informáticos, y los activos de información, datos almacenados, transmitidos o procesados, o los servicios correspondientes ofrecidos por dichos sistemas y que puedan afectar al normal funcionamiento de los mismos.
- **Integridad:** Atributo de los activos y activos de información relativo a la exactitud, autenticidad y completitud de los mismos.
- **Plataforma electrónica (en adelante también "plataforma"):** Software o conjunto de software, datos e infraestructura tecnológica que sustenta procesos o procedimientos.
- **Riesgo:** Efecto de la incertidumbre sobre los activos de información y los objetivos de una entidad, habitualmente expresado en relación con las consecuencias de un evento o incidente de seguridad y su probabilidad de ocurrencia.
- **Servidor:** Equipo virtual o físico dedicado a entregar servicios de red, servicios de bases de datos, sitios web, sistemas informáticos, carpetas compartidas y, en general, brindar los recursos necesarios para responder las peticiones de usuarios.
- **Sistema Informático:** Conjunto de componentes lógicos y físicos que, interactuando entre sí, permiten que su totalidad o una parte de ellos, realicen la función para la cual fueron diseñados.
- **Usuarios(as):** Personas naturales o sus apoderados(as), y los(as) representantes de las personas jurídicas o entidades y agrupaciones sin personalidad jurídica que actúan como interesados(as) en un procedimiento administrativo, así como los(as) funcionarios(as) que acceden a las plataformas electrónicas que soportan procedimientos administrativos o procesos relacionados con estos.

11 REVISIÓN Y MEDICIÓN

A lo menos una vez al año, el Comité de Seguridad de la Información MINSAL debe evaluar el estado del SGSI e informar al nivel directivo de los resultados, considerando cambios que surjan en el transcurso de este período que podrían afectar el enfoque de la organización a la gestión de la seguridad de la información, incluyendo cambios al ambiente de la organización, circunstancias del negocio, disponibilidad de recursos, condiciones contractuales, reguladoras, y legales, o cambios al ambiente técnico. Para ello debe considerar los siguientes aspectos:

- Retroalimentación de las partes interesadas.
- Resultados de las revisiones efectuadas por terceras partes.
- Estado de acciones preventivas y correctivas.
- Cambios en los procesos institucionales, nueva legislación, tecnología etc.
- Alertas ante amenazas y vulnerabilidades.
- Información relacionada a incidentes de seguridad.
- Recomendaciones provistas por autoridades relevantes.
- Medición de los indicadores del Sistema.

12 CUMPLIMIENTO DE LA PRESENTE POLITICA



Todos los usuarios del Ministerio de Salud ya sean funcionarios de planta, contrata, honorarios, asesores, consultores, practicantes, y otros trabajadores, deberán dar cumplimiento, en lo que les corresponda, a esta Política General de Seguridad de la Información, las políticas específicas y los procedimientos relacionados que se aprueben al efecto. Además, aplica a todos los proveedores tecnológicos y terceros que tengan relaciones contractuales con el MINSAL y el sector salud, de acuerdo con la naturaleza y el alcance de cada proyecto.

Cada uno de estos actores debe seguir de manera rigurosa las políticas y procedimientos específicos que se aprueben para este propósito, asegurando así la protección de la información crítica, la continuidad operativa y la resiliencia de la infraestructura tecnológica del sistema de salud.

13 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS

▪ Marco Normativo

- NCh-ISO27001:2013: Tecnología de la información - Técnicas de seguridad - Sistemas de gestión de la seguridad de la información – Requisitos.
- El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
 - Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
 - Leyes relacionadas

▪ Documentos Relacionados

- Documento del Sistema de Gestión de Seguridad de la Información del Ministerio de Salud, disponibles en intranet a través de <http://isalud.minsal.cl> y en sitio web https://www.minsal.cl/seguridad_de_la_informacion/

▪ Leyes o Decretos

- Ley 19.650, que perfecciona las normas del área de la salud.
- Ley N° 19.966, que Establece un Régimen de Garantías Explícitas en Salud. La Ley N°19.966 fue promulgada el 25 de agosto de 2004 y publicada el 03 de septiembre de 2004.
- Ley N° 19.628, de 1999, Ministerio Secretaría General de la Presidencia, sobre protección de la vida privada.
- Ley N° 19.799, de documentos y firmas electrónicas
- Ley N° 20.285, de 2008, Ministerio Secretaría General de la Presidencia, sobre acceso a la información pública.
- Ley N° 20.584, de 2012, Ministerio de Salud, Subsecretaría de Salud Pública, regula derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud.
- Ley N° 20.120, de 2006, Ministerio de Salud, Subsecretaría de Salud Pública, sobre la investigación científica en el ser humano, su genoma, y prohíbe la clonación humana.
- Ley N° 20.724, de 2014, Ministerio de Salud, modifica el código sanitario en materia de regulación de farmacias y medicamentos.
- D.F.L. N°29, de 2005, Ministerio de Hacienda, que fija texto refundido, coordinado y sistematizado de la Ley N° 18.834, sobre estatuto Administrativo.

Decreto con Fuerza de Ley N° 1/19653, Ministerio Secretaría General de la Presidencia, que fija texto refundido, coordinado y sistematizado de la ley N° 18.575, orgánica constitucional de Bases Generales de la Administración del Estado.



Capacitación	Capacitar a los funcionarios en seguridad de la información no solo protege a la organización de amenazas cibernéticas, sino que también contribuye a crear una cultura de seguridad consciente y proactiva en toda la institución.
--------------	---

A continuación, se presentan los distintos indicadores por área:

Cobertura de la norma ISO 27001

- Número de Controles Implementados: Mide cuántos de los controles de seguridad especificados en ISO 27001 han sido implementados en la organización.
- Nivel de Documentación de Políticas y Procedimientos: Mide cuántas de las políticas y procedimientos de seguridad requeridos por ISO 27001 han sido documentados.

Niveles de madurez

- Medición del Nivel de madurez (de acuerdo con el modelo de madurez del PMI) en los procesos operativos y de gestión de seguridad de la información, según el marco de Seguridad ISO 27001.

Gestión de incidentes

- Tasa de Incidentes de Seguridad: Registra la cantidad de incidentes de seguridad reportados en un período determinado. Esto puede incluir intentos de intrusión, phishing, malware, etc.
- Tiempo de Resolución de Incidentes: Mide el tiempo que lleva resolver y cerrar un incidente de seguridad después de haber sido detectado.

Análisis de vulnerabilidades técnicas

- Vulnerabilidades Críticas por Aplicación: Calcula la cantidad de vulnerabilidades de seguridad críticas (de alto riesgo) identificadas en cada aplicación.
- Tiempo Promedio de Resolución de Vulnerabilidades: Mide el tiempo que lleva resolver las vulnerabilidades de seguridad identificadas, desde su descubrimiento hasta su resolución completa.

Capacitación

- Capacitación en Seguridad: Calcula el porcentaje de funcionarios que han recibido capacitación en seguridad de la información según lo definido en ISO 27001.

15 MECANISMO DE DIFUSIÓN.

La comunicación de la presente política se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en sitioweb de Minsal http://www.minsal.cl/seguridad_de_la_informacion/
- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

16 PERÍODO DE REVISIÓN.

La revisión del contenido de esta Política se efectuará a lo menos cada dos años por el Comité de Seguridad de la Información, o atendiendo necesidades de cambios para garantizar su idoneidad, adecuación y efectividad.



